Práctica PKI con XCA — Modo Campo (Toolbox-OT)

Objetivo: cada alumno genera su **par de claves** y obtiene un **certificado** firmado por la **CA de clase** (el profesor). Con ese certificado, el profesor **cifra y firma** la base de datos de activos, y el alumno la consulta en campo con la app **Modo Campo** (móvil, sin portátil).

Herramienta: **XCA** (https://hohnstaedt.de/xca/) — gestor de PKI/certificados multiplataforma.

Conceptos que practicas: clave pública/privada, **CSR** (petición de firma), **CA**, **cadena de confianza**, **cifrado híbrido** (AES + RSA-OAEP) y **firma digital**.

Parte 0 — (Profesor) Crear la CA de clase

1. Abre XCA → **File → New Database** (ponle contraseña; p. ej. `aula.xdb`).
2. Pestaña **Certificates → New Certificate**. - *Source*: **Create a self signed certificate**. - *Subject*: rellena `commonName = CA Clase OT` (y organización, etc.). - Pestaña *Extensions* → *Type* = **Certification Authority**. - Genera también su clave (RSA 2048). **Aceptar**.
3. Exporta el certificado de la CA: selecciónalo → **Export → PEM (*.crt)** → `ca.crt`. (Este `ca.crt` lo necesitarán todos y el empaquetador.)

Parte 1 — (Alumno) Generar tu clave y tu petición (CSR)

Cada alumno trabaja en **su propia** base de datos XCA.

1. **File → New Database** (p. ej. `alumno.xdb`, con contraseña).
2. Pestaña **Private Keys → New Key** → tipo **RSA**, tamaño **2048**. Nómbrala `Alumno-<tu nombre>`.
3. Pestaña **Certificate signing requests → New Request**. - *Source*: **Create a certificate signing request**. - *Private key*: elige la clave que acabas de crear. - *Subject*: `commonName = Alumno <tu nombre>` (y los campos que indique el profesor). - **Aceptar.**
4. Exporta la petición: selecciona el CSR → **Export → PEM (*.pem* / .csr)** → `alumno.csr`.

5. **Entrega `alumno.csr` al profesor** (correo, carpeta compartida...). **Tu clave privada NO se entrega nunca.**

Parte 2 — (Profesor) Firmar el CSR con la CA

En la base de datos de la CA:

1. **Importa** el CSR del alumno: pestaña **Certificate signing requests → Import** → `alumno.csr`.
2. Pestaña **Certificates → New Certificate**. - *Source*: **Sign this Certificate signing request** → selecciona el CSR del alumno. - *Use this Certificate for signing*: selecciona la **CA Clase OT**. - *Extensions* → *Type* = **End Entity**. Caducidad p. ej. 1–2 años. - **Aceptar.**
3. Exporta el certificado firmado del alumno: selecciónalo → **Export → PEM (*.crt)** → `alumno-<nombre>.crt`.
4. **Devuelve `alumno-<nombre>.crt` al alumno.** Guarda una copia: el empaquetador la usará como destinatario.

Parte 3 — (Alumno) Montar tu identidad y exportar el `.p12`

De vuelta en tu base de datos XCA:

1. **Importa** tu certificado firmado: **Certificates → Import** → `alumno-<nombre>.crt`. (XCA lo enlaza automáticamente con tu clave privada.)
2. **Importa** también el `ca.crt` del profesor (**Certificates → Import**), para que la cadena quede completa.
3. Selecciona **tu** certificado → **Export → PKCS#12 (*.p12)**. - Marca **"Export the Certificate chain"** (así el `.p12` incluye también la CA). - Pon una **contraseña** (la recordarás en la app). → `mi_identidad.p12`.

Ese `.p12` contiene: **tu clave privada + tu certificado + la CA**. Es tu "identidad" para el Modo Campo. **Protégelo**: si alguien obtiene tu `.p12` y su contraseña, puede descifrar la base.

Parte 4 — (Profesor) Empaquetar la base de datos

Con los `.crt` de los alumnos autorizados, el `ca.crt`, y el certificado+clave del profesor (puedes usar la propia CA como firmante, o un certificado "Profesor"

emitido por la CA):

```
./empaquetar.sh  inventario.json  inventario.p7  profesor.crt  profesor.key  ca.crt \
                 alumno-ana.crt  alumno-luis.crt  alumno-eva.crt
```

- **Firma** el inventario con `profesor.crt/key` (la CA avala la firma).
- **Cifra** una copia para **cada** alumno indicado (RSA-OAEP + AES-256).
- Resultado: `inventario.p7` → repártelo a los alumnos (no es secreto: va cifrado).

> El `inventario.json` es el proyecto exportado desde la app de Análisis de Riesgo. **Autorización/revocación:** quien no esté en la lista de `-recip` **no podrá abrirlo**.

Parte 5 — (Alumno) Consultar en campo

1. Abre **Modo Campo** en el móvil (la URL que te dé el profesor; o instálala como app).
2. **Paso 1:** importa tu `mi_identidad.p12` + contraseña.
3. **Paso 2:** carga `inventario.p7`. La app **descifra** con tu clave y **verifica la firma** de la CA. - Si la firma no es de la CA de clase (o el archivo se manipuló) → **aviso rojo y no muestra datos**.
4. **Paso 3: escanea el QR** del equipo (o teclea el código `A001`) → ves la ficha del activo.

Preguntas para el aula

- ¿Por qué el QR del equipo lleva **solo el código** y no la IP? (pista: reconocimiento del atacante)
- ¿Qué protege el **cifrado** y qué protege la **firma**? ¿Puede haber una sin la otra?
- ¿Qué pasa si un alumno pierde su `.p12`? ¿Y si lo pierde **con** la contraseña apuntada al lado?
- ¿Cómo revocarías el acceso de un alumno a futuras entregas?
- RSA-OAEP vs RSA PKCS#1 v1.5: ¿por qué el navegador exige OAEP?